

PLAN DE GESTION DES RISQUES ET DE CONTINUITÉ D'ACTIVITÉ

ZOLA MONEY TRANS — Agrégateur de Paiement Marchand
Éditeur de Logiciels Fintech | Swazi Appli Lab SARL
« **Paiement Marchand** »

Destinataire	Banque Centrale du Congo (BCC) — Direction de la Surveillance des Systèmes de Paiement
Objet	Dossier de demande de licence — Éditeur de Logiciels & Agrégateur de Paiement
Référence	Instruction BCC n°42/2020 — Monétique en RDC
Version	v2.0 — Mai 2026
Classement	CONFIDENTIEL — Usage BCC uniquement
Auteurs	Bob Nawej (CEO) Dr Emmanuel Nduwa, PhD IT (CTO)
Entité légale	Swazi Appli Lab SARL — RCCM enregistré en RDC
Contact urgent	+243 993 242 872 (CEO) +243 857 767 040 (CTO)

Ce document constitue la pièce centrale de gestion des risques soumise à la Banque Centrale du Congo dans le cadre de la demande de licence fintech de Zola Money Trans. Il décrit exhaustivement l'identification des risques, leur évaluation, les dispositifs de prévention, les procédures d'urgence, le plan de continuité d'activité (PCA), et les mécanismes de protection des utilisateurs conformément aux exigences de la BCC.

DOCUMENT CONFIDENTIEL — REPRODUCTION INTERDITE SANS AUTORISATION ÉCRITE

TABLE DES MATIÈRES

- 1. CADRE RÉGLEMENTAIRE ET GOUVERNANCE DES RISQUES**
- 2. CARTOGRAPHIE GLOBALE DES RISQUES — MATRICE D'ÉVALUATION**
- 3. RISQUES OPÉRATIONNELS ET TECHNIQUES**
 - 3.1 Panne de la plateforme / Indisponibilité du service
 - 3.2 Défaillance d'un opérateur Mobile Money partenaire
 - 3.3 Erreur de transaction (double débit, non-crédit)
 - 3.4 Défaillance des API partenaires
- 4. RISQUES DE CYBERSÉCURITÉ**
 - 4.1 Cyberattaque DDoS
 - 4.2 Intrusion et violation de données (Data Breach)
 - 4.3 Fraude par ingénierie sociale (Phishing, SIM-Swap)
 - 4.4 Compromission des clés cryptographiques
- 5. RISQUES DE FRAUDE ET DE BLANCHIMENT (AML/CFT)**
 - 5.1 Fraude à l'identité et usurpation de compte
 - 5.2 Transactions suspectes / Blanchiment d'argent
 - 5.3 Financement du terrorisme
 - 5.4 Fraude interne (collaborateur malveillant)
- 6. RISQUES RÉGLEMENTAIRES ET DE CONFORMITÉ**
 - 6.1 Non-conformité aux exigences BCC
 - 6.2 Ordre de suspension de la BCC
 - 6.3 Violation de la protection des données personnelles
- 7. RISQUES LIÉS AUX PARTENAIRES ET À LA CHAÎNE D'APPROVISIONNEMENT**
- 8. RISQUES FINANCIERS**
- 9. PLAN DE CONTINUITÉ D'ACTIVITÉ (PCA)**
 - 9.1 Organisation de crise — Cellule de Gestion de Crise
 - 9.2 Niveaux d'alerte et escalade
 - 9.3 Procédures détaillées par scénario de crise
 - 9.4 Plan de reprise après sinistre (DRP)
- 10. COMMUNICATION DE CRISE — PROTECTION DES UTILISATEURS**
- 11. AUDITS, TESTS ET AMÉLIORATION CONTINUE**
- 12. CONTACTS D'URGENCE 24H/7J**

1. CADRE RÉGLEMENTAIRE ET GOUVERNANCE DES RISQUES

Zola Money Trans opère sous le cadre réglementaire de la Banque Centrale du Congo, conformément à l'**Instruction BCC n°42/2020** relative aux règles applicables à la monétique en République Démocratique du Congo. En tant qu'agrégateur de paiement et éditeur de logiciels fintech, Zola Money Trans ne détient à aucun moment les fonds des utilisateurs. Ce modèle réduit significativement le risque financier systémique, mais impose une rigueur extrême sur la sécurité technique, la continuité de service et la protection des données.

1.1 Base légale et références normatives

Référence	Domaine	Application Zola Money Trans
Instruction BCC n°42/2020	Monétique & paiement électronique	Cadre général d'exploitation — licences Éditeur + Agrégateur
Loi n°04/016 du 19 juillet 2004	Lutte contre le blanchiment d'argent (AML)	Procédures KYC, monitoring, CENAREF
Loi n°22/073 (Cybersécurité RDC)	Sécurité informatique	Protection des systèmes, notification incidents
RGPD / Loi protection données PDRD	Données personnelles	KYC, conservation données 10 ans, droits utilisateurs
PCI-DSS (standard international)	Sécurité des paiements	Chiffrement, contrôles d'accès, tests de pénétration
ISO/IEC 27001	Sécurité de l'information	SMSI, gestion des risques, continuité d'activité
ISO 22301	Continuité d'activité	PCA, DRP, tests de reprise
FATF/GAFI Recommandations	AML/CFT internationales	Procédures LBC/FT, déclarations CENAREF

1.2 Gouvernance des risques — Structure organisationnelle

La gouvernance des risques de Zola Money Trans est structurée selon un modèle à trois lignes de défense, conformément aux meilleures pratiques internationales :

Ligne de défense	Acteur	Responsabilité
1ère ligne — Opérationnelle	Équipe technique (CTO Dr Nduwako)	Détection et résolution opérationnelle des incidents. Monitoring temps réel. Implémentation des contrôles
2ème ligne — Contrôle	Compliance Officer	Supervision de la conformité BCC/AML/KYC. Évaluation des risques. Reporting
3ème ligne — Audit	Auditeur externe indépendant	Audit annuel indépendant. Tests de pénétration semestriels. Certification ISO 27001
Niveau stratégique	CEO Bob Nawej + Conseil	Décisions en cas de crise majeure. Relations BCC. Approbation des politiques

2. CARTOGRAPHIE GLOBALE DES RISQUES — MATRICE D'ÉVALUATION

La matrice ci-dessous présente l'ensemble des risques identifiés, leur probabilité d'occurrence, leur impact potentiel sur les utilisateurs et les opérations, ainsi que le niveau de risque résiduel après application des mesures de mitigation. L'échelle utilisée est : **P = Probabilité (1-Faible / 2-Modérée / 3-Élevée)** ; **I = Impact (1-Mineur / 2-Modéré / 3-Critique)** ; **Score = P × I** ; **Criticité : 1-2 Faible (vert) / 3-4 Modéré (orange) / 6-9 Élevé (rouge)**.

#	Risque	Catégorie	P	I	Score	Criticité
R-01	Panne plateforme / indisponibilité	Opérationnel	2	3	6	ÉLEVÉ
R-02	Défaillance opérateur MM partenaire	Opérationnel	2	3	6	ÉLEVÉ
R-03	Erreur de transaction (double débit)	Opérationnel	2	3	6	ÉLEVÉ
R-04	Défaillance API partenaires	Technique	2	2	4	MODÉRÉ
R-05	Cyberattaque DDoS	Cybersécurité	3	3	9	ÉLEVÉ
R-06	Violation de données (Data Breach)	Cybersécurité	1	3	3	MODÉRÉ
R-07	Phishing / SIM-Swap utilisateurs	Cybersécurité	3	2	6	ÉLEVÉ
R-08	Compromission clés cryptographiques	Cybersécurité	1	3	3	MODÉRÉ
R-09	Fraude à l'identité / Usurpation	Fraude/AML	2	3	6	ÉLEVÉ
R-10	Blanchiment d'argent	Fraude/AML	2	3	6	ÉLEVÉ
R-11	Financement du terrorisme	Fraude/AML	1	3	3	MODÉRÉ
R-12	Fraude interne (collaborateur)	Fraude/AML	1	3	3	MODÉRÉ
R-13	Non-conformité BCC	Réglementaire	1	3	3	MODÉRÉ
R-14	Ordre de suspension BCC	Réglementaire	1	3	3	MODÉRÉ
R-15	Violation données personnelles	Réglementaire	1	2	2	FAIBLE
R-16	Défaillance fournisseur cloud (Google)	Partenaires	1	3	3	MODÉRÉ
R-17	Résiliation contrat opérateur MM	Partenaires	1	2	2	FAIBLE
R-18	Volatilité CDF/USD (taux de change)	Financier	2	2	4	MODÉRÉ
R-19	Insuffisance de liquidité technique	Financier	1	2	2	FAIBLE
R-20	Perte de réputation suite à incident	Stratégique	2	3	6	ÉLEVÉ

✓ **Aucun risque résiduel ÉLEVÉ n'est accepté sans plan de mitigation actif et validé. Tous les risques de score ≥ 6 font l'objet d'un plan de traitement prioritaire détaillé dans les sections suivantes.**

3. RISQUES OPÉRATIONNELS ET TECHNIQUES

3.1 — R-01 : Panne de la plateforme / Indisponibilité du service [ÉLEVÉ]

■ **Impact direct sur les utilisateurs : transactions impossibles, commerçants bloqués, perte de confiance.**

Description du risque

Une indisponibilité de la plateforme Zola Money Trans empêche tout paiement marchand ou transfert inter-opérateurs. Dans le contexte RDC, où les utilisateurs peuvent dépendre de la plateforme pour des paiements vitaux (SNEL, REGIDESO, alimentation), même une panne courte peut avoir un impact social significatif.

Causes potentielles

- Défaillance de l'infrastructure Google Firebase / GCP
- Surcharge soudaine du trafic (pic de transactions)
- Erreur de déploiement d'une mise à jour logicielle
- Coupure réseau ou internet (fréquente en RDC)
- Maintenance non planifiée d'un service tiers

Mesures de prévention

Mesure	Détail	Statut
SLA Google Cloud 99.99%	Contrat de niveau de service garanti par Google Cloud Platform	Actif
Architecture multi-région	Déploiement simultané Europe (Belgique) + US comme failover automatique	Actif
Health checks automatiques	Vérification toutes les 60 secondes — alerte si réponse >2 sec	Actif
Load balancer Firebase	Répartition automatique de la charge sur plusieurs instances	Actif
Mode dégradé (graceful degradation)	l'app affiche les services disponibles et désactive automatiquement les services défaillants	Actif
Page de statut publique	status.zolamoneytrans.com mis à jour en temps réel	Actif

Procédure de réponse — Timeline

Temps	Action	Responsable
T+0 min	Alerte automatique Firebase Monitoring — notification SMS + Slack #ops-alerts	Système automatique
T+2 min	CTO Dr Nduwa notifié — diagnostic initial (dashboard GCP, logs Firebase)	CTO
T+5 min	Identification de la cause racine — décision : correction directe ou basculement région	CTO + Équipe Tech
T+10 min	Si non résolu : activation du failover automatique région Europe → US	CTO
T+15 min	Mise à jour page statut publique — notification push aux utilisateurs actifs	CTO + Comm
T+30 min	Si toujours non résolu : escalade CEO + ouverture ticket critique Google Support	CEO + CTO
T+60 min	Si panne >1h : notification BCC (email + téléphone Compliance Officer)	Compliance Officer
T+4h	Objectif de retour à la normale — rapport d'incident interne	CTO
T+24h	Rapport incident complet envoyé à la BCC (si panne >1h)	Compliance Officer
T+72h	Rapport de cause racine (RCA) et plan de mesures correctives	CTO + Auditeur

✓ **Objectif de disponibilité : 99.9% (soit maximum 8h45 d'indisponibilité cumulée par an). Toute indisponibilité supérieure à 15 minutes déclenche automatiquement le protocole de communication utilisateurs.**

3.2 — R-02 : Défaillance d'un opérateur Mobile Money partenaire [ÉLEVÉ]

■ **Impact : les paiements via l'opérateur défaillant sont impossibles. Les utilisateurs dont le compte est sur cet opérateur ne peuvent pas initier de transactions.**

Causes potentielles

- Panne technique interne de l'opérateur (M-Pesa, Airtel, Orange)
- Maintenance planifiée ou non planifiée de l'opérateur
- Révocation temporaire d'accès API (dépassement de quota, problème de facturation)
- Résiliation du contrat de partenariat
- Problèmes réglementaires de l'opérateur avec la BCC

Mesures de prévention et mitigation

L'architecture agrégateur de Zola Money Trans est conçue nativement pour la redondance des opérateurs. Aucun opérateur unique n'est un point de défaillance critique grâce aux mécanismes suivants :

- **Monitoring temps réel de chaque opérateur** : ping API toutes les 2 minutes — statut affiché en temps réel
- **Routage automatique** : si un opérateur est indisponible, le système bascule automatiquement sur l'opérateur de secours pour les corridors compatibles
- **Indicateur visuel utilisateur** : opérateurs indisponibles affichés grisés avec message explicite
- **Contrats avec 3 opérateurs minimum** : M-Pesa, Airtel Money, Orange Money — redondance sur chaque corridor
- **Alertes contractuelles** : les SLA des APIs partenaires prévoient une notification préalable de toute maintenance planifiée (48h minimum)

Procédure de réponse

Temps	Action	Responsable
T+0	Détection automatique : 3 pings consécutifs échoués → opérateur marqué INDISPONIBLE	Système
T+2 min	SMS automatique à l'équipe technique + notification sur dashboard	Opérateur.
T+5 min	CTO vérifie : panne opérateur ou problème API Zola. Contact hotline technique	Opérateur.
T+10 min	Activation affichage maintenance pour l'opérateur concerné sur l'interface utilisateur	Équipe Tech
T+30 min	Communication utilisateurs : SMS ciblés aux utilisateurs de l'opérateur concerné	Communication
T+2h	Si panne prolongée : évaluation impact financier — rapport interne	CEO + CFO
T+24h	Rapport à la BCC si l'indisponibilité affecte >10% de la base utilisateurs	Compliance

3.3 — R-03 : Erreur de transaction (double débit, non-crédit) [ÉLEVÉ]

■ **Impact critique : un utilisateur peut être débité sans que le bénéficiaire soit crédité. Atteinte directe à la confiance et perte financière pour l'utilisateur.**

Description

Une erreur de transaction peut survenir si la communication entre Zola et l'API de l'opérateur est interrompue après le débit mais avant la confirmation de crédit. Ce scénario est l'un des plus sensibles car il affecte directement les fonds en transit.

Architecture de prévention — Idempotence et atomicité

- **Idempotence des transactions** : chaque transaction est identifiée par un UUID unique. Une transaction ne peut être exécutée qu'une seule fois, même si la requête est répétée.
- **Pattern Saga / Compensation** : si l'étape de crédit échoue après le débit, une transaction de remboursement automatique est déclenchée dans les 60 secondes.
- **États de transaction clairs** : PENDING → PROCESSING → SUCCESS / FAILED / REFUNDED. Aucun état ambigu n'est toléré.
- **Timeouts définis** : toute transaction non confirmée sous 120 secondes passe automatiquement en état TIMEOUT → déclenchement du processus de vérification.
- **Réconciliation automatique** : comparaison toutes les heures entre les débits Zola et les confirmations opérateurs. Tout écart génère une alerte immédiate.
- **Journalisation immuable** : chaque étape de transaction est loguée avec horodatage précis (milliseconde) dans Firestore avec règles d'écriture seule (append-only).

Procédure de remboursement automatique

Scénario	Action automatique	Délai max
Débit réussi + Crédit échoué	Remboursement automatique vers compte source de l'utilisateur	60 secondes
Timeout sans confirmation	Transaction marquée TIMEOUT + notification utilisateur + vérification	120 secondes
Double débit détecté	Gel immédiat du compte + remboursement du débit en excès + alerte Compliance	5 minutes
Écart réconciliation	Alerte CTO + Compliance Officer + investigation + correction sous	4 heures

Procédure de recours utilisateur

- Canal de réclamation disponible 24h/7j : chat in-app, email support@zolamoneytrans.com, téléphone
- Délai de traitement des réclamations : 24h ouvrables maximum
- Remboursement garanti sous 72h en cas d'erreur confirmée de la plateforme
- Suivi de réclamation avec numéro de ticket unique communiqué à l'utilisateur
- Rapport mensuel des réclamations transmis à la BCC

3.4 — R-04 : Défaillance des API partenaires [MODÉRÉ]

■ **Impact modéré : certains services spécifiques sont indisponibles (paiement SNEL, recharges) sans bloquer l'ensemble de la plateforme.**

- **Circuit breaker pattern** : après 5 échecs consécutifs sur une API, le circuit est ouvert automatiquement — requêtes stoppées pendant 60 secondes, puis test progressif
- **Cache des données statiques** : les tarifs, catalogues et références clients sont mis en cache local pour fonctionner même si l'API partenaire est lente
- **File d'attente de retry** : les transactions non critiques en temps sont mises en file d'attente et rejouées automatiquement (max 3 tentatives)
- **Monitoring des latences** : alerte si temps de réponse API >3 secondes (dégradation) ou timeout >10 secondes (incident)

4. RISQUES DE CYBERSÉCURITÉ

4.1 — R-05 : Cyberattaque DDoS (Déni de Service Distribué) [ÉLEVÉ]

■ **Risque le plus probable en cybersécurité. Une attaque DDoS peut rendre la plateforme totalement inaccessible en quelques minutes, impactant l'ensemble des utilisateurs.**

Description

Une attaque DDoS consiste à saturer les serveurs Zola Money Trans avec un volume massif de requêtes artificielles, rendant le service indisponible pour les utilisateurs légitimes. Les fintechs sont des cibles privilégiées pour ce type d'attaque, notamment par des acteurs malveillants cherchant à perturber les opérations ou à extorquer une rançon.

Dispositifs de protection

Dispositif	Description	Capacité de protection
Google Cloud Armor (WAF)	Pare-feu applicatif de niveau entreprise — filtrage intelligent du trafic malveillant	Protection contre les Tbps d'attaques
Rate Limiting	Limitation du nombre de requêtes par IP, par utilisateur, par endpoint	Blocage de requêtes configurables
Challenge CAPTCHA adaptatif	Déclenchement automatique si comportement suspect détecté (filtre de bots)	Filtrage automatisé
Géo-restriktion configurable	Possibilité de restreindre l'accès à certaines géographies si attaque localisée	Sélection géographique
Anycast IP Firebase	Le trafic est automatiquement distribué sur le réseau mondial Google (POP RDC Afrique)	Atténuation de l'impact d'attaque
Alertes volumétriques	Alerte si le trafic dépasse 3x la moyenne sur les 24h précédentes	Détection précoce

Procédure de réponse DDoS

Temps	Action	Responsable
T+0	Cloud Armor détecte et bloque automatiquement le trafic malveillant — alerte Système de Sécurité	Système de Sécurité
T+2 min	CTO notifié — analyse du tableau de bord d'attaque (volume, origine, vecteur)	CTO
T+5 min	Ajustement des règles Cloud Armor en temps réel si nécessaire (blocage IP range)	CTO + Équipe Sécu
T+10 min	Activation du mode protection renforcée : CAPTCHA sur toutes les requêtes	CTO
T+15 min	Si services affectés : communication statut utilisateurs	Communication
T+30 min	Si attaque persiste : contact Google Security Support (SLA 15 min réponse)	CTO
T+2h	Rapport incident interne + notification BCC si services impactés >1h	Compliance
T+24h	Rapport d'analyse forensic de l'attaque — mise à jour règles de protection	CTO + Auditeur
T+72h	Rapport complet BCC + notification CERT-RDC (si attaque significative)	CEO + Compliance

4.2 — R-06 : Intrusion et violation de données (Data Breach) [MODÉRÉ]

■ **Impact critique pour les utilisateurs : exposition des données KYC personnelles (pièce d'identité, selfie, numéro de téléphone). Obligation légale de notification BCC et utilisateurs.**

Mesures de prévention — Défense en profondeur

- **Principe du moindre privilège** : chaque composant n'a accès qu'aux données strictement nécessaires à sa fonction

- **Segmentation des données** : données KYC séparées des données transactionnelles — bases distinctes avec chiffrement AES-256 indépendant
- **Chiffrement au repos** : toutes les données sont chiffrées avec des clés gérées par Google Cloud KMS — rotation des clés tous les 90 jours
- **Accès administrateur** : authentification multi-facteurs obligatoire (MFA) + clé physique FIDO2 pour tous les accès administrateur
- **Logs d'accès** : tout accès aux données sensibles est journalisé avec identité, horodatage, action
- **Tests d'intrusion semestriels** : par auditeur externe certifié CEH/OSCP — rapport et corrections obligatoires
- **Scan de vulnérabilités automatique** : analyse hebdomadaire du code et des dépendances (OWASP ZAP + Snyk)

Procédure de réponse — Violation de données

Phase	Actions	Délai
Détection	Alerte automatique (Google Cloud Security Command Center) + notification équipe de sécurité	Immédiat
Confinement (0-1h)	Isolation du composant compromis. Révocation des tokens d'accès suspects. Blocage des comptes compromis.	1 heure
Évaluation (1-4h)	Identification de la portée : quelles données, combien d'utilisateurs, quelle durée d'exposition	4 heures
Notification BCC (4-24h)	Rapport initial à la BCC incluant : nature de l'incident, données affectées, mesure de réponse	24 heures
Notification utilisateurs	SMS + notification push aux utilisateurs dont les données sont potentiellement exposées	48 heures
Remédiation	Correction de la vulnérabilité + audit complet + renforcement des contrôles	< 7 jours
Rapport final BCC	Rapport complet : chronologie, impact, mesures correctives, plan de prévention	< 30 jours

4.3 — R-07 : Fraude par ingénierie sociale (Phishing, SIM-Swap) [ÉLEVÉ]

■ **Risque très fréquent en RDC. Des fraudeurs se font passer pour Zola Money Trans pour voler les identifiants ou le code PIN des utilisateurs.**

Vecteurs d'attaque identifiés

- **Phishing par SMS** : SMS frauduleux prétendant venir de Zola, demandant de 'vérifier' le compte via un lien malveillant
- **SIM-Swap** : le fraudeur convainc l'opérateur télécom de transférer le numéro de la victime sur une nouvelle SIM, prenant le contrôle de l'OTP SMS
- **Faux agents Zola** : appels téléphoniques de fraudeurs se présentant comme support Zola et demandant le PIN
- **Applications frauduleuses** : clones de l'application Zola publiés sur des stores non officiels

Mesures de protection des utilisateurs

- **Politique 'Zola ne demande jamais votre PIN'** : message affiché à chaque connexion et dans les communications officielles
- **Détection SIM-Swap** : vérification de cohérence de l'IMSI SIM à chaque connexion — alerte et blocage si changement SIM récent (<24h)
- **Délai de sécurité post-SIM-Swap** : blocage automatique des transactions 24 heures après tout changement de SIM détecté

- **Notification de connexion** : SMS automatique à chaque nouvelle connexion avec indication du pays/opérateur détecté
- **Blocage compte sur signalement** : l'utilisateur peut bloquer son compte en 1 clic ou via SMS au numéro court Zola
- **Programme d'éducation** : tutoriels de sensibilisation intégrés dans l'app, SMS éducatifs périodiques, campagnes radio partenaires
- **URL officielle unique** : app.zolamoneytrans.com — tout autre domaine est frauduleux (publicité de ce principe)

Procédure si compte compromis signalé

- Blocage immédiat du compte sur signalement utilisateur (disponible 24h/7j via SMS)
- Gel de toutes les transactions en cours ou en attente
- Investigation : analyse des logs de connexion des 72 dernières heures
- Réinitialisation sécurisée : nouveau PIN, nouvelle vérification OTP, revalidation KYC
- Remboursement des pertes si fraude confirmée due à une défaillance de la plateforme
- Rapport à la BCC si montant fraudé >500 USD ou si schéma de fraude organisé détecté

4.4 — R-08 : Compromission des clés cryptographiques [MODÉRÉ]

■ **La compromission des clés de chiffrement permettrait à un attaquant de déchiffrer les données sensibles des utilisateurs (KYC, transactions).**

- **Google Cloud KMS** : gestion centralisée des clés par un service certifié FIPS 140-2 Level 3
- **Rotation automatique des clés** : toutes les 90 jours sans interruption de service
- **Séparation des clés** : clés distinctes par catégorie de données (KYC / transactions / sessions)
- **Accès aux clés audité** : chaque utilisation de clé est journalisée avec identité, horodatage, contexte
- **Révocation immédiate** : procédure de révocation d'une clé compromise en moins de 5 minutes
- **Procédure de re-chiffrement** : en cas de compromission avérée, re-chiffrement de toutes les données avec nouvelles clés sous 4 heures

5. RISQUES DE FRAUDE ET DE BLANCHIMENT (AML/CFT)

La lutte contre le blanchiment d'argent (AML) et le financement du terrorisme (CFT) est une priorité absolue de Zola Money Trans, conformément à la Loi n°04/016 et aux recommandations GAFI. Le modèle agrégateur de Zola, qui ne détient pas de fonds, réduit certains risques, mais l'intermédiation des paiements impose des obligations de vigilance strictes sur les flux transitant par la plateforme.

5.1 — R-09 : Fraude à l'identité et usurpation de compte [ÉLEVÉ]

■ Un fraudeur crée un compte avec une fausse identité ou usurpe l'identité d'une vraie personne pour effectuer des transactions frauduleuses.

Dispositif KYC multi-niveaux

Niveau	Déclencheur	Vérifications requises	Limites de transaction
Non-vérifié	Inscription initiale	Email + numéro téléphone OTP uniquement	0 USD — lecture seule
KYC Basic	Activation compte	Pièce d'identité nationale (photo) + selfie de contrôle + téléphone	100 USD/transaction — 500 USD/mois
KYC Avancé	Automatique si dépassement KYC Basic ou selfie biométrique (liveness check) + adresse vérifiée	KYC Basic + selfie biométrique (liveness check) + adresse vérifiée	1 000 USD/transaction — 5 000 USD/mois
KYC Marchand	Inscription commerçant	KYC Avancé + RCCM + documents entreprise + visite terrain	5 000 USD/transaction — 15 000 USD/mois

Contrôles de vérification d'identité

- **Lecture OCR de la pièce d'identité** : extraction et validation automatique des données (nom, date, numéro)
- **Liveness check** : vérification que le selfie est bien une personne réelle (anti-photo, anti-masque)
- **Face-matching** : correspondance biométrique entre le selfie et la photo de la pièce d'identité
- **Vérification base de données nationale** : croisement avec les listes de sanctions OFAC, UE, ONU
- **Règle un-numéro-un-compte** : un numéro de téléphone ne peut être associé qu'à un seul compte actif
- **Délai de carence** : les nouveaux comptes sont soumis à des limites renforcées pendant les 30 premiers jours

5.2 — R-10 : Transactions suspectes et blanchiment d'argent [ÉLEVÉ]

■ Des acteurs malveillants pourraient tenter d'utiliser Zola comme outil de blanchiment en fractionnant des montants importants ou en multipliant les transactions pour dissimuler l'origine des fonds.

Système de monitoring AML temps réel

Zola Money Trans déploie un moteur de détection AML basé sur des règles et sur le Machine Learning (analyse comportementale), opérationnel 24h/24, 7j/7 :

Règle	Seuil / Condition	Action automatique
Seuil de montant unique	Transaction unique > 2 000 USD	Alerte Compliance Officer + vérification manuelle avant exécution
Seuil cumulé journalier	Cumul > 3 000 USD/jour pour un compte	Blocage temporaire + vérification Compliance
Smurfing (fractionnement)	≥5 transactions en 1h vers différents destinataires	Alerte fraude + gel temporaire du compte
Comportement inhabituel	Pays de connexion différent du profil habituel	OTP renforcé + alerte sécurité
Fréquence anormale	ML : score de déviation comportementale > 85%	Mise en surveillance active

Règle	Seuil / Condition	Action automatique
Bénéficiaire sur liste noire	Correspondance avec liste OFAC/UE/ON	Blocage immédiat + signalement CENAREF
Transactions circulaires	Détection de flux A→B→C→A	Gel des comptes impliqués + alerte Compliance
Pics horaires suspects	Volume x10 habituel hors heures ouvrables	Alerte + analyse ML comportement

Procédure de signalement CENAREF

- Toute transaction suspecte identifiée est consignée dans le registre AML interne
- Le Compliance Officer analyse et confirme la suspicion sous 24 heures
- Déclaration de Soupçon (DS) envoyée au CENAREF (Centre National d'Évaluation des Risques de Financement) dans les délais légaux
- Gel du compte concerné pendant la durée de l'enquête
- Coopération totale avec les autorités judiciaires et la BCC si enquête ouverte
- Conservation de toute la documentation pendant 10 ans minimum

5.3 — R-11 : Financement du terrorisme (CFT) [MODÉRÉ]

■ Bien que moins probable, ce risque est traité avec la priorité maximale conformément aux obligations légales et aux recommandations GAFI.

- **Screening liste de sanctions** : vérification de chaque utilisateur et bénéficiaire contre les listes OFAC, Union Européenne, Nations Unies et RDC (actualisation quotidienne automatique)
- **Blocage immédiat et irrévocable** : tout compte correspondant à une liste de sanctions est bloqué instantanément, sans possibilité de transaction
- **Signalement immédiat BCC + CENAREF** : notification dans les 2 heures suivant la détection
- **Pas de notification au client** : conformément à la réglementation, le client concerné n'est pas informé de la raison du blocage
- **Conservation des preuves** : toutes les données et logs du compte sont conservés et mis à disposition des autorités
- **Formation de l'équipe** : formation CFT obligatoire annuelle pour tous les employés accédant aux données de transactions

5.4 — R-12 : Fraude interne (collaborateur malveillant) [MODÉRÉ]

■ Un employé ou prestataire disposant d'accès aux systèmes pourrait tenter de manipuler des transactions ou d'exfiltrer des données.

- **Contrôle d'accès basé sur les rôles (RBAC)** : chaque employé n'accède qu'aux données strictement nécessaires à sa fonction
- **Séparation des tâches** : aucun employé seul ne peut initier ET valider une transaction sensible (principe des 4 yeux)
- **Audit trail de chaque action admin** : toute action administrative est journalisée avec identité, horodatage et justification
- **Revue trimestrielle des droits d'accès** : vérification que les droits sont toujours appropriés — suppression immédiate lors de départ d'un employé
- **Alerte sur actions sensibles** : toute tentative d'accès en dehors des heures ouvrables ou à des données hors scope génère une alerte

- **Vérifications des antécédents** : vérification judiciaire obligatoire pour tout employé accédant aux systèmes de production

6. RISQUES RÉGLEMENTAIRES ET DE CONFORMITÉ

6.1 — R-13 : Non-conformité aux exigences BCC [MODÉRÉ]

■ **Le non-respect des exigences de la BCC peut entraîner des sanctions, amendes, ou la suspension de la licence.**

- **Compliance Officer dédié** : responsable exclusif du suivi des obligations réglementaires BCC
- **Veille réglementaire active** : abonnement aux publications BCC, participation aux consultations du secteur
- **Calendrier de conformité** : toutes les obligations périodiques (reporting mensuel, audits annuels) sont planifiées avec alertes automatiques 30 jours avant l'échéance
- **Rapport mensuel BCC automatisé** : génération automatique du rapport de conformité avec données vérifiées — envoi le 5 de chaque mois
- **Relation proactive avec la BCC** : réunions trimestrielles de revue avec la Direction de la Surveillance — transparence totale
- **Audit interne semestriel** : vérification de la conformité avant tout audit externe

6.2 — R-14 : Ordre de suspension de la BCC [MODÉRÉ — TRAITEMENT PRIORITAIRE]

■ **Un ordre de suspension de la BCC doit être exécuté immédiatement. La protection des utilisateurs pendant la période de suspension est critique.**

Protocole de réponse à un ordre de suspension

Étape	Action	Délai	Responsable
1 — Réception	Réception de l'ordre BCC (email officiel + téléphone). Accusé de réception immédiat	10 minutes	CEO + Compliance
2 — Mobilisation	Activation cellule de crise : CEO, CTO, Compliance Officer, Avocat	30 minutes	CEO
3 — Suspension	Désactivation de toutes les nouvelles transactions sur la plateforme	1 heure	CTO
4 — Transactions sécurisées	Finalisation sécurisée des transactions déjà initiées (ou remboursement)	2 heures	CTO + Compliance
5 — Communication	Notification push : 'Service temporairement suspendu - 2 heures' + transactions sécurisées	2 heures	Service Client
6 — Rapport	Rapport de confirmation d'exécution de l'ordre + état des transactions	12 heures	Compliance
7 — Plan de remédiation	Identification des causes + plan de mesures correctives + demande de levée de l'ordre de suspension	48 heures	CEO + CTO + Avocat
8 — Suivi	Rapport quotidien à la BCC jusqu'à levée de la suspension	Quotidien	Compliance

Protection des utilisateurs pendant la suspension

- Aucun fonds utilisateur n'est conservé par Zola — les fonds restent chez les opérateurs Mobile Money
- Les utilisateurs sont dirigés vers leurs opérateurs respectifs pour effectuer leurs transactions directement
- Le service client reste opérationnel pour répondre aux questions et réclamations
- Remboursement de toutes les commissions prélevées sur les transactions non exécutées

6.3 — R-15 : Violation de la protection des données personnelles [FAIBLE]

- **Base légale de traitement** : consentement explicite de l'utilisateur recueilli lors de l'inscription — politique de confidentialité claire en français

- **Minimisation des données** : seules les données strictement nécessaires au KYC et aux transactions sont collectées
- **Droits des utilisateurs** : droit d'accès, de correction et de suppression (dans les limites légales de conservation 10 ans)
- **Conservation sécurisée** : données KYC chiffrées AES-256 dans une base isolée — accès restreint et audité
- **Sous-traitants engagés** : contrats DPA avec Google (GCP) incluant les garanties de protection des données

7. RISQUES LIÉS AUX PARTENAIRES ET À LA CHAÎNE D'APPROVISIONNEMENT

Partenaire	Risque	Impact	Mitigation
Google Firebase / GCP	Défaillance infrastructure cloud	Élevé	SLA 99.99% contractuel — multi-région — backup autre cloud en Phase
Vodacom M-Pesa	Indisponibilité API ou résiliation	Élevé	3 opérateurs alternatifs — contrats SLA — préavis 90 jours contractuel
Airtel Money	Indisponibilité API ou résiliation	Élevé	Idem — routage automatique vers opérateurs disponibles
Orange Money	Indisponibilité API ou résiliation	Élevé	Idem — minimum 2 opérateurs toujours actifs requis
Flexpaie	Défaillance du partenaire de paiement	Moyen	Intégration directe opérateurs en backup — dépendance Flexpaie réduite
SNEL / REGIDESO	Indisponibilité API de paiement	Faible	File d'attente + retry automatique — service non critique temps réel

Une **politique de diversification des partenaires** est appliquée : aucun partenaire unique ne représente plus de 40% du volume de transactions. Des audits annuels de la solidité financière et technique des partenaires clés sont effectués. Des clauses contractuelles de préavis (minimum 90 jours) et de portabilité des données sont incluses dans tous les contrats partenaires.

8. RISQUES FINANCIERS

Risque	Description	Mitigation
R-18 : Volatilité CDF/USD	Fluctuation du taux de change impactant les frais de transaction	Pricing transparent USD révisé mensuellement des taux — couverture partielle
R-19 : Liquidité technique	Insuffisance de trésorerie pour payer les frais de transaction	Réserve de trésorerie partielle de 3 mois de charges opérationnelles —
R-20 : Perte de réputation	Incident médiatisé (fraude, panne) entraînant une fuite massive de clients	Confrontation de crise préparée — KPI de suivi de la réputation — pro
Risque fiscal	Changement de la fiscalité applicable aux transactions digitales	Adaptation fiscale locale — flexibilité du modèle de pricing
Risque de commission	Réduction des commissions par les opérateurs de paiement	Diversification des canaux de paiement — abonnements marchands —

9. PLAN DE CONTINUITÉ D'ACTIVITÉ (PCA)

9.1 — Organisation de crise — Cellule de Gestion de Crise (CGC)

La Cellule de Gestion de Crise est activée dès qu'un incident atteint le Niveau 2 (voir 9.2). Elle est permanente, joignable 24h/7j, et ses membres ont des suppléants identifiés.

Rôle	Titulaire	Contact 24h/7j	Suppléant
Directeur de Crise (CEO)	Bob Nawej	+243 993 242 872	Dr Emmanuel Nduwa
Directeur Technique (CTO)	Dr Emmanuel Nduwa	+243 857 767 040 +268 785 159 70	Lead Developer Swazi
Compliance Officer	À nommer (Phase 1)	Dédié BCC/AML	CEO par intérim
Responsable Communication	À nommer (Phase 1)	Dédié communication crise	CEO par intérim
Conseil Juridique	Avocat partenaire externe	Selon accord de retenir	Cabinet de secours
Contact Google Support	Compte GCP Premium Support	SLA 15 min (critique)	N/A

9.2 — Niveaux d'alerte et procédures d'escalade

Niveau	Critères de déclenchement	Équipe mobilisée	Rapport BCC
NIV. 0 VEILLE	Anomalie détectée sans impact utilisateur. Alerte monitoring déclenchée.	Équipe technique en-call	Non requis
NIV. 1 MINEUR	Impact <100 utilisateurs. Indisponibilité <15 min. Aucune perte de données. Fraude isolée <500 USD (interne)	OTC + Opérations + IT	Non requis
NIV. 2 MAJEUR	Impact >100 utilisateurs. Indisponibilité 15 min - 2h. Suspicion de fraude >500 USD. Violation de données potentielle.	OTC + Compliance + IT	Non requis
NIV. 3 CRITIQUE	Impact >1 000 utilisateurs. Indisponibilité >2h. Violation de données confirmée. Fraude organisée >5 000 USD. Cyberattaque.	OTC + Avocats + Compliance + IT	Non requis
NIV. 4 RÈGLEMENT.	Ordre de suspension BCC. Enquête judiciaire. Injonction réglementaire.	OTC Réglementaire. Avocat + BCC	Non requis

9.3 — Procédures détaillées par scénario de crise

SCÉNARIO A — Panne Majeure de la Plateforme (NIV. 2-3)

Temps	Action précise	Outil / Canal	Resp.
T+0	Alerte monitoring Firebase → notification auto SMS + Slack	Alerte Monitoring / PagerDuty	Auto
T+2 min	CTO connecté au dashboard GCP — identification du composant défaillant	GCP Console	CTO
T+5 min	Diagnostic : Firebase Functions / Firestore / Auth / Réseau	GCP Logs Explorer	CTO
T+10 min	Si Firebase region défaillante : activation basculement Europe VS Amérique	Firebase VS Integration config	CTO
T+10 min	Page statut mise à jour : 'Nous rencontrons un incident technique, nous révoquons vos données'	Frontend	CTO
T+15 min	Notification push + SMS utilisateurs actifs : 'Service perturbé, nous sommes désolés'	Firebase + SMS Gateway	Comm.
T+30 min	Si non résolu : activation NIV. 3 — CEO notifié — ticket	Google Support Center	CEO+CTO
T+60 min	Notification BCC préliminaire si panne >1h : email + téléphone	Frontend + BCC BCC	Compliance
T+4h	Objectif retour normal. Notification résolution aux utilisateurs	ECM + SMS + statut	Comm.
T+24h	Rapport incident complet BCC : chronologie, cause, impact	Formulaires officiels	Compliance
T+72h	RCA (Root Cause Analysis) interne + plan de mesures préventives	Documents interne	CTO

SCÉNARIO B — Fraude Massive Détectée (NIV. 2-3)

Déclenchement : >10 cas de fraude détectés en 1 heure, ou montant fraudé >5 000 USD cumulé.

Temps	Action précise	Outil / Canal	Resp.
T+0	Système AML détecte le schéma frauduleux — alerte Slack	Alerte AML + SMS Compliance	Auto
T+5 min	Compliance Officer analyse le schéma : type de fraude, comptes impliqués, montant	Comptes AML	Compliance
T+10 min	Gel immédiat de tous les comptes impliqués dans le schéma	Firebase Admin SDK	CTO+Compliance
T+15 min	Activation NIV. 2 : CEO notifié — cellule de crise partielle	Téléphone	CEO
T+30 min	Investigation forensic : logs des 72h des comptes concernés	GCP Log Analytics	CTO
T+1h	Rapport préliminaire interne : nature, ampleur, vecteur d'attaque, comptes victimes	Tableaux de bord	Compliance
T+2h	Notification aux utilisateurs victimes : 'Votre compte a été temporairement sécurisé'	Status page	Comm.
T+4h	Déclaration de Soupçon au CENAREF si blanchiment suspecté	Formulaire DS CENAREF	Compliance
T+24h	Rapport BCC complet : schéma, montants, mesures prises	Formulaires officiels	Compliance
T+48h	Remboursement des utilisateurs victimes (si fraude plateforme partenaire)	Compensation	CEO+CFO
T+7 jours	Audit externe du système AML — renforcement des règles	Audit externe	CTO+Auditeur

SCÉNARIO C — Cyberattaque Active (NIV. 3)

Temps	Action précise	Outil / Canal	Resp.
T+0	Cloud Armor détecte attaque DDoS / Intrusion — alerte Cloud Armor SOC	Cloud Armor SOC	Auto
T+2 min	CTO mobilisé — identification du type d'attaque (DDoS, intrusion, etc.)	Google Cloud Security Dashboard	CTO
T+5 min	Activation du mode protection renforcée Cloud Armor — Google Cloud Platform	Google Cloud Platform	CTO
T+5 min	Isolation du composant compromis si intrusion confirmée	Firebase Admin + GCP	CTO
T+10 min	Activation NIV. 3 : CEO + Avocat notifiés	Téléphone	CEO
T+15 min	Page statut : 'Maintenance de sécurité en cours — vos données sont protégées'	Site web	Comm.
T+30 min	Contact Google Security Support (SLA 15 min pour comptes GCP Critical)	Google Security Support	CTO
T+1h	Évaluation de la violation : données exposées ? Transactions compromises ?	Fonctionnaires	CTO+Auditeur
T+2h	Notification BCC immédiate : type d'attaque, impact évalué	Emails / Téléphone BCC	CEO+Compliance
T+4h	Notification CERT-RDC (Centre national cybersécurité)	Canal officiel CERT	CTO+Compliance
T+24h	Si données exposées : notification utilisateurs impactés	SMS + Push	Comm.
T+72h	Audit de sécurité externe d'urgence — rapport complet	Auditeur CEH/OSCP	CTO+Auditeur
T+7 jours	Rapport final BCC + plan de sécurisation renforcé + tests de pénétration	Fonctionnaires officiels	Compliance

SCÉNARIO D — Ordre de Suspension de la BCC (NIV. 4)

✓ Ce scénario fait l'objet d'une attention particulière. La protection des utilisateurs est la priorité absolue. Zola Money Trans n'opère aucune détention de fonds : les utilisateurs ne perdent aucune somme.

Temps	Action précise	Outil / Canal	Resp.
T+0	Réception de l'ordre BCC (voie officielle). Accusé de réception immédiat BCC	Email officiel BCC	CEO
T+15 min	Mobilisation complète CGC : CEO + CTO + Compliance	Téléphone / Signal	CEO
T+30 min	Désactivation de toutes nouvelles transactions (Cloud Firestore Admin Console)	Firebase Admin Console	CTO
T+45 min	Finalisation sécurisée des transactions DÉJÀ INITIÉES (Monitoring transactions)	Monitoring transactions	CTO
T+1h	SMS + Push à TOUS les utilisateurs : service suspendu	FCM / SMS / Email	Comm.
T+2h	Rapport de confirmation d'exécution à la BCC : heure de suspension, état des transactions	Fonctionnaires BCC	Compliance
T+4h	Analyse juridique avec Avocat : motif de suspension — recours possible	Réunion	CEO+Avocat
T+12h	Rapport détaillé BCC : toutes les actions prises, état de l'enquête	Canal officiel BCC	Compliance
T+24h	Rapport quotidien BCC. Disponibilité du service client pour les BCC et SMS users	Email BCC / SMS	Compliance+Comm.
T+48h	Soumission du plan de remédiation à la BCC : causes identifiées, mesures correctives	Document officiel BCC	CEO+Avocat+Compliance
Continue	Rapport quotidien BCC jusqu'à levée de la suspension	Email officiel BCC	Compliance

9.4 — Plan de Reprise après Sinistre (Disaster Recovery Plan — DRP)

Le DRP définit les objectifs de reprise et les procédures techniques permettant de restaurer le service Zola Money Trans après un sinistre majeur (destruction de datacenter, perte totale de données, etc.).

Objectif	Définition	Cible Zola
RPO (Recovery Point Objective)	Perte de données maximale acceptable — correspond à la fréquence des sauvegardes	1 heure maximum
RTO (Recovery Time Objective)	Durée maximale de l'interruption avant reprise complète du service	4 heures maximum
MTTR (Mean Time To Repair)	Temps moyen de résolution d'un incident	< 2 heures (incidents courants)
MTBF (Mean Time Between Failures)	Durée moyenne entre deux pannes	Objectif > 90 jours
Disponibilité cible	Pourcentage de disponibilité annuelle	99.9% (< 8h45 downtime/an)

Architecture de sauvegarde

- **Sauvegarde Firestore** : export automatique toutes les heures vers Google Cloud Storage (bucket dédié chiffré AES-256)
- **Rétention des sauvegardes** : 7 jours quotidiens — 4 semaines hebdomadaires — 12 mois mensuels
- **Sauvegarde multi-région** : les données sont répliquées automatiquement dans 2 régions Google distinctes
- **Test de restauration** : test mensuel de restauration complète depuis sauvegarde — résultat documenté
- **Sauvegarde du code** : repository Git avec branches protégées — historique complet — déploiement scriptés
- **Configuration as Code** : toute la configuration infrastructure est versionnée (Terraform/Firebase config) — restauration en <30 min

10. COMMUNICATION DE CRISE — PROTECTION DES UTILISATEURS

La communication de crise est un pilier de la protection des utilisateurs. Zola Money Trans s'engage à communiquer de manière transparente, rapide et adaptée à chaque niveau d'incident.

10.1 — Principes de communication de crise

- **Rapidité** : première communication dans les 15 minutes suivant un incident NIV. 2+
- **Honnêteté** : pas de minimisation — les utilisateurs sont informés de la réalité de la situation
- **Fréquence** : mise à jour toutes les 30 minutes pendant un incident actif
- **Clarté** : langage simple, sans jargon technique — traduit en langues locales si nécessaire
- **Protection prioritaire** : premier message = réassurance sur la sécurité des fonds/données

10.2 — Canaux de communication et messages types

Canal	Utilisé pour	Délai d'activation	Template disponible
Page statut publique status.zolamoneytrans.com	Tout incident NIV. 1+	< 15 min	Oui — automatisé
Notification push in-app (FCM)	Utilisateurs actifs des 7 derniers jours	< 15 min	Oui — 5 templates
SMS masse	Tous les utilisateurs enregistrés (incident NIV. 2+)	< 15 min	Oui — 3 templates
Email	Commerçants et utilisateurs KYC Avancé	< 1h	Oui
WhatsApp Business	Utilisateurs ayant activé le canal	< 30 min	Oui
Communiqué BCC (format réglementaire)	Tout incident NIV. 2+ et rapport mensuel	< 24h (NIV2) / < 2h (NIV3)	Oui — format BCC
Presse / Médias	Incidents impactant >100 000 utilisateurs	Après l'accord de l'ARF + Avocat	Oui — communiqué type

10.3 — Messages types préparés (templates)

Situation	Message type
Incident technique (général)	«■ Service Zola momentanément perturbé. Nos équipes travaillent activement à la résolution. Vos fonds sont en sécurité.»
Maintenance planifiée	«■ Maintenance programmée le [DATE] de [H1] à [H2]. Le service Zola sera temporairement indisponible. Planifiez vos opérations en conséquence.»
Résolution d'incident	«■ Bonne nouvelle ! Le service Zola est pleinement rétabli depuis [HEURE]. Nous nous excusons pour la gêne occasionnée.»
Alerte sécurité compte	«■ Alerte sécurité Zola : une connexion inhabituelle a été détectée sur votre compte. Si ce n'est pas vous, bloquez votre compte immédiatement.»
Suspension BCC	«■ Zola Money Trans suspend temporairement ses services conformément à une décision réglementaire. Vos fonds sont en sécurité.»

11. AUDITS, TESTS ET AMÉLIORATION CONTINUE

La gestion des risques est un processus vivant et continu. Zola Money Trans s'engage à une culture d'amélioration permanente, testée régulièrement et documentée pour la BCC.

Activité	Fréquence	Acteur	Livrable
Test de restauration backup	Mensuel	CTO + Équipe Tech	Rapport de test avec RTO/RPO mesuré
Revue des droits d'accès	Trimestriel	CTO + Compliance	Rapport de conformité RBAC
Simulation de crise (exercice table top)	Trimestriel	CGC complète	Rapport d'exercice + actions correctives
Audit de conformité AML/KYC interne	Semestriel	Compliance Officer	Rapport de conformité BCC
Test de pénétration (pentest)	Semestriel	Auditeur externe CEH/OSCP	Rapport de vulnérabilités + corrections
Audit de sécurité ISO 27001	Annuel	Auditeur certifié externe	Rapport d'audit + plan de traitement
Audit financier et de conformité BCC	Annuel	Expert-comptable + Compliance	Rapport annuel BCC
Revue complète du plan de risques	Annuel	CGC + Conseil Administration	Plan de risques mis à jour
Test d'interruption planifiée (Chaos Engineering)	Semestriel	CTO	Rapport de résilience
Scan de vulnérabilités automatique (OWASP ZAP)	Quotidien	Système automatique	Rapport automatique — alertes si critique
Mise à jour listes de sanctions (OFAC/UE/ONU)	Quotidien	Système automatique	Log de mise à jour

11.1 — Indicateurs de performance de la gestion des risques (KRI)

Indicateur (KRI)	Cible	Alerte si
Disponibilité mensuelle de la plateforme	> 99.9%	< 99.5%
Délai moyen de résolution d'incident (MTTR)	< 2 heures	> 4 heures
Taux de transactions réussies	> 99.5%	< 99%
Délai de remboursement en cas d'erreur	< 24 heures	> 72 heures
Nombre de faux positifs AML / mois	< 5% du total alertes	> 10%
Délai de traitement des réclamations	< 24h ouvrables	> 48h
Score de vulnérabilités critiques ouvertes	= 0 (zero tolerance)	> 0 (action immédiate)
Délai de soumission rapport BCC mensuel	Avant le 5 du mois	Après le 5 du mois
Taux de complétion KYC des utilisateurs actifs	> 95%	< 90%

12. CONTACTS D'URGENCE 24H/7J

Ces contacts sont opérationnels à tout moment. En cas d'incident majeur, la séquence d'appel suit l'ordre indiqué ci-dessous. Toute communication non répondue dans les 10 minutes entraîne le passage au contact suivant dans la chaîne.

Priorité	Rôle	Nom	Téléphone	Email
1	CEO / Directeur de Crise	Bob Nawej	+243 993 242 872	bob@zolamoneytrans.com
2	CTO / Directeur Technique	Dr Emmanuel Nduwa	+243 857 767 040 +268 785 159 70	emmanuel@zolamoneytrans.com
3	Support Technique (Swazi)	Équipe Swazi Appli Lab	Via CTO	tech@swaziapplilab.co.za
4	Compliance Officer	À nommer Phase 1	À définir	compliance@zolamoneytrans.com
5	Google Cloud Support	GCP Premium Support	Via console GCP	SLA 15 min (incident critique)
6	BCC — Direction Surveillance	Banque Centrale du Congo	Numéro officiel BCC	Via canal officiel BCC
7	CENAREF	Centre National AML	Numéro officiel CENAREF	Via formulaire DS officiel
8	CERT-RDC	Cybersécurité nationale	Numéro officiel CERT	Via canal officiel
9	Avocat / Conseil juridique	Cabinet partenaire	À définir (retenir)	À définir

Canaux de communication interne de crise

Canal	Usage	Accès
Slack #crisis-room	Communication temps réel équipe interne pendant incident	CEO, CTO, Compliance, Comm.
Slack #ops-alerts	Alertes automatiques monitoring — 24h/7j	Équipe technique
Slack #aml-alerts	Alertes AML automatiques	Compliance + CTO
Signal (groupe CGC)	Communication sécurisée hors-ligne (si Slack indisponible)	Membres CGC uniquement
status.zolamoneytrans.com	Communication publique statut — mise à jour manuelle ou auto	Public + BCC
Email sécurisé BCC	Communications officielles vers la BCC	CEO + Compliance

Établi par	Validé par	Date de révision
Dr Emmanuel Nduwa CTO — PhD IT Swazi Appli Lab SARL	Bob Nawej CEO — Zola Money Trans Swazi Appli Lab SARL	Mai 2026 — Version 2.0

DOCUMENT CONFIDENTIEL — ZOLA MONEY TRANS © 2025-2026 — Swazi Appli Lab SARL Reproduction, distribution ou utilisation sans accord écrit préalable strictement interdite. Ce document est soumis à la Banque Centrale du Congo dans le cadre du dossier de demande de licence fintech.